The final section in this chapter doesn't deal with a single vulnerability. Instead, I discuss a separate but related problem: protecting your users' data.

29.4.4 Protecting your users' passwords and data

For many apps, the most sensitive data you'll be storing is the personal data of your users. This could include emails, passwords, address details, or payment information. You should be careful when storing any of this data. As well as presenting an inviting target for attackers, you may have legal obligations for how you handle it, such as data protection laws and Payment Card Industry (PCI) compliance requirements.

The easiest way to protect yourself is to not store data you don't need. If you don't need your user's address, don't ask for it. That way, you can't lose it! Similarly, if you use a third-party identity service to store user details, as described in chapter 23, you won't have to work as hard to protect your users' personal information.

If you store user details in your own app or build your own identity provider, then you need to make sure to follow best practices when handling user information. The new project templates that use ASP.NET Core Identity follow most of these practices by default, so I highly recommend you start from one of these. You need to consider many aspects, too many to go into detail here,[1] but they include the following:

- Never store user passwords anywhere directly. You should store only cryptographic hashes computed using an expensive hashing algorithm, such as BCrypt or PBKDF2.
- Don't store more data than you need. You should never store credit card details.